

Principais Ameaças e Defesas Estruturais

Além dos recursos específicos, o Back-End deve implementar defesas estruturais para garantir a integridade do sistema.

1. Prevenção de Injeção (SQL Injection)

Ataque: É o ataque onde o invasor tenta “enviar comandos” dentro de campos de texto comuns para ler ou apagar o banco de dados.

Defesa: Uso de Prepared Statements (Consultas Preparadas). O sistema trata o que o usuário digita estritamente como “texto” e nunca como “comando”.

2. Gestão de Erros no Lado do Servidor

Logs detalhados para o desenvolvedor, mensagens genéricas para o usuário.

→ Exibir um erro técnico (Stack Trace) no navegador pode revelar a versão da sua linguagem de programação ou a estrutura das suas tabelas.

3. Rate Limiting (Limite de Requisições)

Evita que robôs ou usuários mal-intencionados tentem adivinhar senhas (ataque de força bruta) fazendo milhares de tentativas por segundo.

Se um mesmo IP tentar logar 10 vezes em um minuto, o Back-End bloqueia temporariamente aquele acesso.

Diagrama: Ameaças e Defesas Estruturais

(Transcrição descritiva do diagrama ilustrativo apresentado ao lado do texto original)

SQL Injection

Fluxo: Usuário envia Código Malicioso → passa por Prepared Statements → é tratado como Texto → chega à Database de forma segura.

Gestão de Erros

Fluxo: Server Console recebe o erro → gera um Log do Desenvolvedor (detalhado) → e exibe ao usuário apenas uma Mensagem Genérica.

Rate Limiting

Fluxo: Usuário faz múltiplas tentativas de acesso → ao atingir 10 tentativas → o IP é bloqueado temporariamente → acesso negado (“ACCESSD”) por 60 segundos.